

מודול 11 — פוסט-אקספלוויטציה והסלמת הרשאות — תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1.  תרגול — מודול 11: פוסט-אקספלוויטציה והסלמת הרשאות

תרגול — מודול 11: פוסט-אקספלוויטציה והסלמת הרשאות

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרחיש מהחיים האמיתיים.

חלק א' — שאלות תרגול

- Q1.** מהם שלושת השלבים העיקריים אחרי קבלת Shell ראשוני?
- Q2.** למה מייצבים Shell גולמי, ומהי שיטת ה-Python לכך?
- Q3.** מהו קובץ SUID, ולמה הוא וקטור הסלמה? מה זה GTFOBins?
- Q4.** מה בודקים עם `sudo -l`, ואיך זה מוביל להסלמה?
- Q5.** מהי הרשאת `SeImpersonatePrivilege` ב-Windows, ולמה היא מסוכנת?
- Q6.** מה עושים LinPEAS/WinPEAS, ולמה הם שימושיים?
- Q7.** מהו Looting, ואיך הוא מתחבר לתנועה רוחבית (מודול 12)?
- Q8.** מהי משמעות המשפט "הסלמת הרשאות = 90% Enumeration"?

תשובות

- Enumeration** מקומי → **Looting** → **Privilege Escalation** (+ Persistence בהרשאה).
- Shell גולמי חסר Tab/חצים/Ctrl; `python3 -c 'import pty; pty.spawn("/bin/bash")'`; `Ctrl+C`; `stty raw -echo; fg` +
- קובץ שרץ בהרשאות הבעלים (root); אם מאפשר הרצת פקודות → הסלמה. **GTFOBins** = מאגר שמסביר איך לנצל כל בינארי.
- אילו תוכניות מותר להריץ כ-sudo; אם אחת מאפשרת "בריחה" לפקודת מערכת (vim/find/awk) → `root`.
- הרשאה להתחזות ל-token של משתמש אחר; שירותי IIS/MSSQL מחזיקים אותה → **Potato** → **SYSTEM** → **attacks**.

6. סקריפטי Enumeration אוטומטיים שסורקים מאות וקטורים ומדגישים את הסבירים — חוסכים זמן ומפחיתים החמצות.
7. איסוף סיסמאות/hashtes/מפתחות; משמשים ל-Pass-the-Hash ולכניסה למכונות אחרות ברשת (מודול 12/13).
8. הפער כמעט תמיד "יושב" במידע שכבר קיים במערכת — קובץ, שירות, סיסמה; מי שאוסף טוב, מסלים.

חלק ב' — תרחיש מהחיים האמיתיים

📖 ממשתמש `www-data` עד לרשת הפנימית

פרצת שרת web של חברה דרך File Upload (מודול 9) וקיבלת Shell כ-`www-data`. המטרה: להגיע ל-`root`, ומשם לרשת הפנימית.

1. `shell` → `python3 pty`.
2. Enumeration → LinPEAS: `sudo NOPASSWD /usr/bin/python3`.
3. הסלמה → `sudo python3 -c 'import os; os.system("/bin/bash")' → root`.
4. Looting → `/etc/shadow (crack)`, `config.php` עם סיסמת DB,
!מפתח לשרת נוסף → `~/.ssh/id_rsa`
5. פנימי (מודול 12) DB תנועה → המפתח פותח שרת.

המשימה: 1. מדוע `sudo python3` הוא הסלמה מיידית? כתוב את הפקודה המדויקת. 2. איזה מהפריטים ב-Looting הוא **המסוכן ביותר** לרשת, ולמה? 3. מה **המלצת התיקון** המרכזית שהיית כותב ללקוח?

💡 פתרון מנחה

1. `python3` מאפשר הרצת פקודות מערכת; כ-`sudo` הן רצות כ-`root`: `sudo python3 -c 'import os; os.system("/bin/bash")'`
2. **מפתח ה-Ssh הפרטי (`id_rsa`)** — הוא פותח גישה למכונות **אחרות** ברשת ללא סיסמה, ומאפשר תנועה רוחבית מיידית.
3. הסר `NOPASSWD` מ-`python3 (least-privilege)`, אחסן מפתחות פרטיים בהרשאות מוגבלות, והפרד את שרת ה-web מהרשת הפנימית (`segmentation`).

🎯 שרשרת "`root` → `web` → מפתח → מכונה הבאה" היא בדיוק איך פריצות אמיתיות מתגלגלות.
Post-Exploitation טוב = ההבדל בין ממצא בודד לפריצה מלאה.

